

FICBANK

Enterprise Cybersecurity Modernization

Technical Controls Report

Prepared By: *Caleb Tetteh*

Portfolio Edition - Version 1.0

Table of Contents

1. Executive Summary	4
2. Technical Control Scope	5
2.1 Project Scope	Error! Bookmark not defined.
2.2 Security Objectives	6
2.3 Protected Infrastructure.....	7
2.4 Systems and Expected Services	7
2.5 Security Architecture Assumptions.....	11
3. Technical Control Implementation Details	12
3.1 Zero Trust Architecture	16
3.2 Network Segmentation and Internal Firewalls	25
3.3 Identity and Access Management (IAM).....	33
4. Test and Evaluation Plan.....	62
4.1 Test and Evaluation Objectives.....	62
4.2 Security Control Validation Strategy	64
4.3 Zero Trust Architecture Validation.....	65
4.4 Network Segmentation and Firewall Validation	66
4.5 Identity and Access Management Validation	67
4.6 Splunk Enterprise Security SIEM Validation.....	68
4.7 Endpoint Detection and Response Validation	68

4.8 Vulnerability Management Validation	69
4.9 Continuous Monitoring and Assessment	71
5. Conclusion	71
References	74

1. Executive Summary

Following three cybersecurity assessment engagements, FICBANK requested a Technical Controls Report to transform previously identified vulnerabilities into a practical cybersecurity modernization strategy. Earlier assessments identified numerous vulnerabilities including exposed administrative services, limited security monitoring, and evidence of exploitation attempts targeting internet-facing systems. Collectively, these findings demonstrated that FICBANK's security architecture requires modernization to address evolving cyber threats while improving operational resilience and regulatory compliance (NIST, 2020a; CISA, 2023).

This report recommends an integrated defense-in-depth security architecture that addresses the risks identified throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases. The proposed technical controls strengthen identity security, network protection, endpoint security, centralized security monitoring, and vulnerability management while enhancing business continuity, regulatory compliance, and organizational resilience. Rather than implementing isolated technologies, the recommended architecture integrates preventive, detective, corrective, and governance controls into a coordinated security framework that reduces enterprise risk and improves cybersecurity maturity (NIST, 2020a; NIST, 2020b).

The proposed architecture incorporates Zero Trust principles and layered security controls to reduce the risk of unauthorized access, ransomware, malware, privilege escalation, and lateral movement (Rose et al., 2020). The recommendations align with NIST SP 800-53 Rev. 5, NIST SP 800-207, the CISA Zero Trust Maturity Model, FFIEC guidance, PCI DSS v4.0, and the GLBA Safeguards Rule, providing FICBANK with a scalable security strategy that strengthens customer trust and supports future organizational growth (DoD, 2022; CISA, 2023).

2. Technical Control Scope

2.1 Engagement Scope

The scope of this technical control implementation encompasses the enterprise information systems, supporting infrastructure, and security technologies that enable FICBANK's daily banking operations. The proposed cybersecurity modernization strategy is based on the cumulative findings from the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases, which identified weaknesses in network segmentation, identity management, vulnerability management, centralized security monitoring, and endpoint protection. Rather than addressing these deficiencies independently, this report recommends an integrated defense-in-depth architecture that strengthens the confidentiality, integrity, and availability of organizational information assets while supporting regulatory compliance, operational resilience, and long-term business continuity (NIST, 2020a).

The implementation scope includes internet-facing services, internal network infrastructure, endpoint devices, identity services, centralized monitoring platforms, backup infrastructure, and cloud-connected resources. Collectively, these systems support essential banking functions including customer authentication, financial transaction processing, employee communications, system administration, and disaster recovery. Because these environments process sensitive financial and customer information, they require layered security controls that continuously reduce organizational risk while maintaining operational availability (NIST, 2020a; FFIEC, 2024).

2.2 Security Objectives

The recommended technical controls are designed to achieve the following strategic cybersecurity objectives:

- Reduce the likelihood of unauthorized access to critical systems and customer information through continuous identity verification and least-privilege access enforcement (Rose et al., 2020).
- Limit attacker lateral movement through Zero Trust principles, network segmentation, and internal firewall policies (CISA, 2023; DoD, 2022).
- Strengthen identity governance using Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), and Privileged Access Management (PAM) (NIST, 2020a).
- Improve enterprise visibility through centralized security monitoring, behavioral analytics, and automated threat detection capabilities (NIST, 2022).
- Enhance vulnerability management using continuous assessment, secure configuration management, authenticated vulnerability scanning, and risk-based patch governance (NIST, 2020a; AWS, 2023).
- Support compliance with recognized cybersecurity frameworks and financial-sector regulatory requirements while improving overall organizational resilience (FFIEC, 2024; PCI SSC, 2022).

Collectively, these objectives establish the strategic direction for the security architecture presented throughout the remainder of this report while supporting FICBANK's long-term cybersecurity maturity.

2.3 Protected Infrastructure

The proposed security architecture protects all major enterprise technology components supporting FICBANK's banking operations. These include Active Directory services, Domain Name System (DNS), email infrastructure, financial application servers, databases, endpoint workstations, backup infrastructure, cloud-connected services, and centralized security monitoring platforms. The architecture also extends protection to internet-facing systems through network segmentation, next-generation firewalls, secure remote access, and intrusion detection capabilities consistent with modern defense-in-depth principles (NIST, 2020a; CISA, 2023).

Because previous assessments identified exposed administrative services and evidence of malicious reconnaissance activity, particular emphasis is placed on protecting privileged accounts, administrative interfaces, and internal communication paths. Security controls are therefore implemented in multiple defensive layers so that compromise of any single component does not provide unrestricted access to enterprise resources. This layered approach reflects Zero Trust principles by requiring continuous verification rather than implicit trust based solely on network location (Rose et al., 2020).

2.4 Systems and Expected Services

Table 2-1. Protected Systems, Expected Services, Primary Threats, and Recommended Security Controls

System	Business Function	Expected Services	Primary Threats	Recommended Security Controls
Domain Controller	Enterprise identity and authentication	Active Directory, LDAP, Kerberos, Group Policy	Credential theft, privilege escalation	MFA, PAM, RBAC, Group Policy hardening
DNS Server	Name resolution	DNS	DNS spoofing, cache poisoning	DNSSEC, logging, access restrictions
DHCP Server	IP address assignment	DHCP	Rogue DHCP servers	Network Access Control (NAC), switch port security
Web Server	Online banking applications	HTTPS, TLS	Web application attacks, remote exploitation	Web Application Firewall (WAF), secure coding, TLS enforcement
Database Server	Financial and customer records	SQL, encrypted connections	SQL injection, data theft	Database encryption, least privilege, activity monitoring

System	Business Function	Expected Services	Primary Threats	Recommended Security Controls
Email Server	Corporate communications	SMTP, HTTPS, IMAP	Phishing, malware, Business Email Compromise (BEC)	Secure email gateway, SPF, DKIM, DMARC, attachment sandboxing
File Server	Shared organizational data	SMB	Ransomware, unauthorized file access	Access Control Lists (ACLs), immutable backups, file integrity monitoring
Backup Infrastructure	Disaster recovery	Backup agents, encrypted replication	Backup deletion, ransomware	Offline and immutable backups, recovery testing
Splunk Enterprise Security SIEM	Centralized monitoring	Syslog, HTTPS, APIs	Log tampering, incomplete visibility	RBAC, log integrity validation, automated alerting

System	Business Function	Expected Services	Primary Threats	Recommended Security Controls
Endpoint Workstations	Employee productivity	Windows services, endpoint agents	Malware, phishing, credential compromise	Endpoint Detection and Response (EDR), BitLocker, application control
Point-of-Sale (POS) Systems	Payment processing	HTTPS	Payment card compromise	Network segmentation, PCI DSS controls, EDR
Network Infrastructure	Internal communications	Routing, switching, VPN	Lateral movement, unauthorized access	Next-Generation Firewalls (NGFW), IDS/IPS, VLAN segmentation
Cloud Services	Cloud-hosted applications	HTTPS, APIs	Misconfiguration, excessive permissions	Cloud Security Posture Management (CSPM), IAM, encryption

The enterprise systems identified in *Table 2-1* represent the critical technology components supporting FICBANK's banking operations. The recommended security controls were selected using a risk-based approach that considers the sensitivity of each system, the

services it provides, the likelihood of exploitation, and the potential business impact of compromise. Implementing layered preventive, detective, and corrective safeguards across these systems reduces organizational exposure to ransomware, credential theft, unauthorized access, insider threats, and service disruption while supporting defense-in-depth and Zero Trust security principles (NIST, 2020a; CISA, 2023).

2.5 Security Architecture Assumptions

The recommended security controls assume that FICBANK will continue expanding its digital banking capabilities while increasing reliance on cloud-based services, centralized monitoring platforms, remote administration, and modern identity services. Consequently, the proposed architecture emphasizes scalability, centralized security management, automation, and continuous monitoring rather than isolated security technologies (DoD, 2022; CISA, 2023).

Successful implementation also assumes that technical controls will be supported by complementary administrative safeguards, including security policies, user awareness training, governance processes, change management, and periodic security assessments. While technology provides the foundation for reducing cyber risk, long-term effectiveness depends upon continuous vulnerability assessment, timely remediation of identified weaknesses, ongoing monitoring of security events, and regular validation of implemented controls (NIST, 2022).

These assumptions establish the operational foundation for the technical control implementation strategy presented in Section 3 and ensure that the proposed safeguards remain effective as FICBANK's technology environment and the cyber threat landscape continue to evolve.

3. Technical Control Implementation Details

The cybersecurity assessments conducted throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases established a comprehensive understanding of FICBANK's security posture and identified several weaknesses that increase organizational exposure to cyber threats. The assessments revealed externally accessible administrative services, limited internal network segmentation, weaknesses in identity governance, incomplete vulnerability management, insufficient centralized monitoring, and evidence of malicious reconnaissance and exploitation attempts. Although each assessment examined different aspects of the environment, the cumulative findings demonstrated that the organization requires a coordinated cybersecurity modernization strategy rather than isolated technology improvements.

The technical controls presented in this report were selected using a risk-based methodology that aligns each recommendation with vulnerabilities and operational deficiencies identified during the previous assessment engagements. Rather than implementing independent security products, FICBANK should adopt an integrated defense-in-depth architecture in which preventive, detective, corrective, and recovery controls operate together to reduce organizational risk. This approach improves the confidentiality, integrity, and availability of business-critical information while strengthening operational resilience, supporting regulatory compliance, and enabling secure business growth.

To demonstrate that each recommendation is supported by assessment evidence, *Table 3-1* maps significant findings from the Network and Vulnerability Assessment, Security

Monitoring Assessment, and Incident and IOC Investigation phases to the proposed security controls and the corresponding validation activities that will be discussed in Section 4. This traceability ensures that every recommendation directly addresses an identified organizational risk while supporting measurable improvements to FICBANK's cybersecurity maturity.

Table 3-1. Mapping Previous Assessment Findings to Recommended Security Controls

Assessment Finding (the first three assessment phases)	Business Risk	Recommended Technical Controls	Section	Validation Summary
Exposed SMB services	Lateral movement and ransomware propagation	Zero Trust Architecture, Network Segmentation, NGFW, Endpoint Detection and Response	3.1, 3.2, 3.5	Authenticated vulnerability scanning, firewall rule verification, lateral movement testing
Exposed Remote Desktop Protocol (RDP)	Unauthorized remote access and credential theft	Multi-Factor Authentication (MFA), Privileged Access Management (PAM),	3.3	MFA validation, privileged access review, remote access testing

Assessment Finding (the first three assessment phases)	Business Risk	Recommended Technical Controls	Section	Validation Summary
		Secure VPN, Jump Servers		
Exposed Secure Shell (SSH) services	Administrative account compromise	Key-based authentication, MFA, secure configuration management	3.3	SSH configuration review, authentication testing
Weak internal network segmentation	Unrestricted east-west movement following compromise	VLAN segmentation, Internal Firewalls, Zero Trust Architecture	3.2	Segmentation validation, firewall testing
Incomplete credentialed vulnerability scanning	Undetected vulnerabilities and delayed remediation	Enterprise Vulnerability Management, Patch Governance	3.6	Credentialed Nessus scans, remediation verification

Assessment Finding (the first three assessment phases)	Business Risk	Recommended Technical Controls	Section	Validation Summary
Shellshock exploitation attempts	Remote code execution and system compromise	Patch Management, Secure Configuration Management, Web Application Firewall (WAF), IDS/IPS	3.2, 3.6	Vulnerability scanning, attack simulation
Malware staging activity	Malware execution and ransomware infection	Endpoint Detection and Response (EDR), Application Control	3.5	Malware simulation, EDR alert validation
Limited centralized monitoring	Delayed detection and incident response	Splunk Enterprise Security SIEM, Centralized Logging, Automated Alerting	3.4	SIEM correlation testing, alert verification
Weak identity governance	Privilege escalation and insider threats	Active Directory Hardening, RBAC, PAM, Conditional Access	3.3	Identity review, access recertification

Assessment Finding (the first three assessment phases)	Business Risk	Recommended Technical Controls	Section	Validation Summary
Flat network architecture	Increased enterprise-wide attack surface	Defense-in-Depth Architecture and Zero Trust	3.1	Architecture review, security control assessment

The recommendations presented throughout the remainder of this section build upon this traceability model. Each control family is described in terms of its implementation objectives, contribution to the overall security architecture, expected business benefits, and alignment with recognized cybersecurity frameworks. Together, these controls establish a layered security strategy that reduces cyber risk while improving FICBANK's ability to detect, respond to, and recover from cybersecurity incidents.

3.1 Zero Trust Architecture

3.1.1 Current Security Challenges

The cumulative cybersecurity assessments performed during the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases demonstrated that FICBANK's existing security architecture relies primarily on traditional perimeter-based defenses, which are insufficient to address today's sophisticated cyber threats. The Network and Vulnerability Assessment identified exposed administrative services,

including Server Message Block (SMB), Remote Desktop Protocol (RDP), and Secure Shell (SSH), increasing the organization's attack surface and creating opportunities for unauthorized remote access, credential theft, privilege escalation, and lateral movement (NIST, 2020a). The Security Monitoring Assessment and Incident and IOC Investigation phases further identified malicious reconnaissance activity, Shellshock exploitation attempts, malware staging, and weaknesses in centralized monitoring, confirming that threat actors may target additional systems following a potential initial compromise within the network. These findings demonstrate that relying solely on perimeter security creates unacceptable operational risk for a financial institution responsible for protecting sensitive customer and financial information.

Traditional trust models assume that users and devices located within the corporate network can be trusted. However, modern threat actors routinely exploit compromised credentials, phishing attacks, ransomware, and supply chain attacks to bypass perimeter defenses and operate within trusted network boundaries. Consequently, FICBANK requires a security architecture that continuously verifies every access request regardless of network location while limiting opportunities for unauthorized access and lateral movement (Rose et al., 2020).

3.1.2 Zero Trust Design Principles

To address these challenges, FICBANK should adopt a Zero Trust Architecture (ZTA) based on the principle of "never trust, always verify" (Rose et al., 2020). Unlike traditional security models that grant broad access once users successfully authenticate to the network, Zero Trust continuously evaluates user identity, device health, application context, geographic location, behavioral characteristics, and resource sensitivity before granting or maintaining

access to enterprise resources (Rose et al., 2020; CISA, 2023). Access decisions become dynamic rather than static, allowing security policies to adapt to changing risk conditions throughout each user session (Rose et al., 2020).

The proposed architecture incorporates several core Zero Trust principles:

- **Continuous Identity Verification** through Multi-Factor Authentication (MFA) and Conditional Access.
- **Least Privilege Access** enforced through Role-Based Access Control (RBAC) and Privileged Access Management (PAM).
- **Micro-Segmentation** to restrict communication between systems and reduce lateral movement.
- **Continuous Monitoring** using Splunk Enterprise Security SIEM and Endpoint Detection and Response (EDR).
- **Assumed Breach Mentality**, in which all access requests are evaluated as though an attacker may already be present within the environment.

Collectively, these principles reduce organizational risk by eliminating implicit trust relationships and ensuring that access decisions are continuously validated according to organizational policy and operational risk (CISA, 2023; DoD, 2022).

3.1.3 Proposed Zero Trust Architecture

The proposed Zero Trust Architecture integrates identity security, network protection, endpoint security, centralized monitoring, and vulnerability management into a unified defense-

in-depth strategy (NIST, 2020a). Rather than functioning as independent technologies, these controls operate together to reduce the likelihood and impact of successful cyberattacks.

The architecture begins with centralized identity management through Active Directory integrated with Multi-Factor Authentication, Role-Based Access Control, Conditional Access policies, and Privileged Access Management (Rose et al., 2020). Users must successfully authenticate using multiple verification factors before access requests are evaluated according to predefined authorization policies. Administrative access is further restricted through dedicated Privileged Access Workstations (PAWs), secure jump servers, and just-in-time privilege elevation to minimize exposure of highly privileged accounts (NIST, 2020a).

Once authenticated, network segmentation policies restrict communication between enterprise systems according to business requirements rather than unrestricted network connectivity. Internal firewalls, virtual LANs (VLANs), and software-defined segmentation enforce logical trust boundaries between workstations, servers, databases, payment systems, and administrative infrastructure (DoD, 2022). Continuous monitoring provided by Splunk Enterprise Security SIEM, Endpoint Detection and Response, and automated alerting enables rapid detection of anomalous behavior, privilege escalation attempts, unauthorized lateral movement, and other indicators of compromise. This integrated architecture significantly improves FICBANK's ability to prevent, detect, contain, and recover from cybersecurity incidents while supporting secure business operations (CISA, 2023).

Figure 3-1. Proposed Defense-in-Depth Security Architecture for FICBANK

Figure 3-1. Proposed Defense-in-Depth Security Architecture for FICBANK

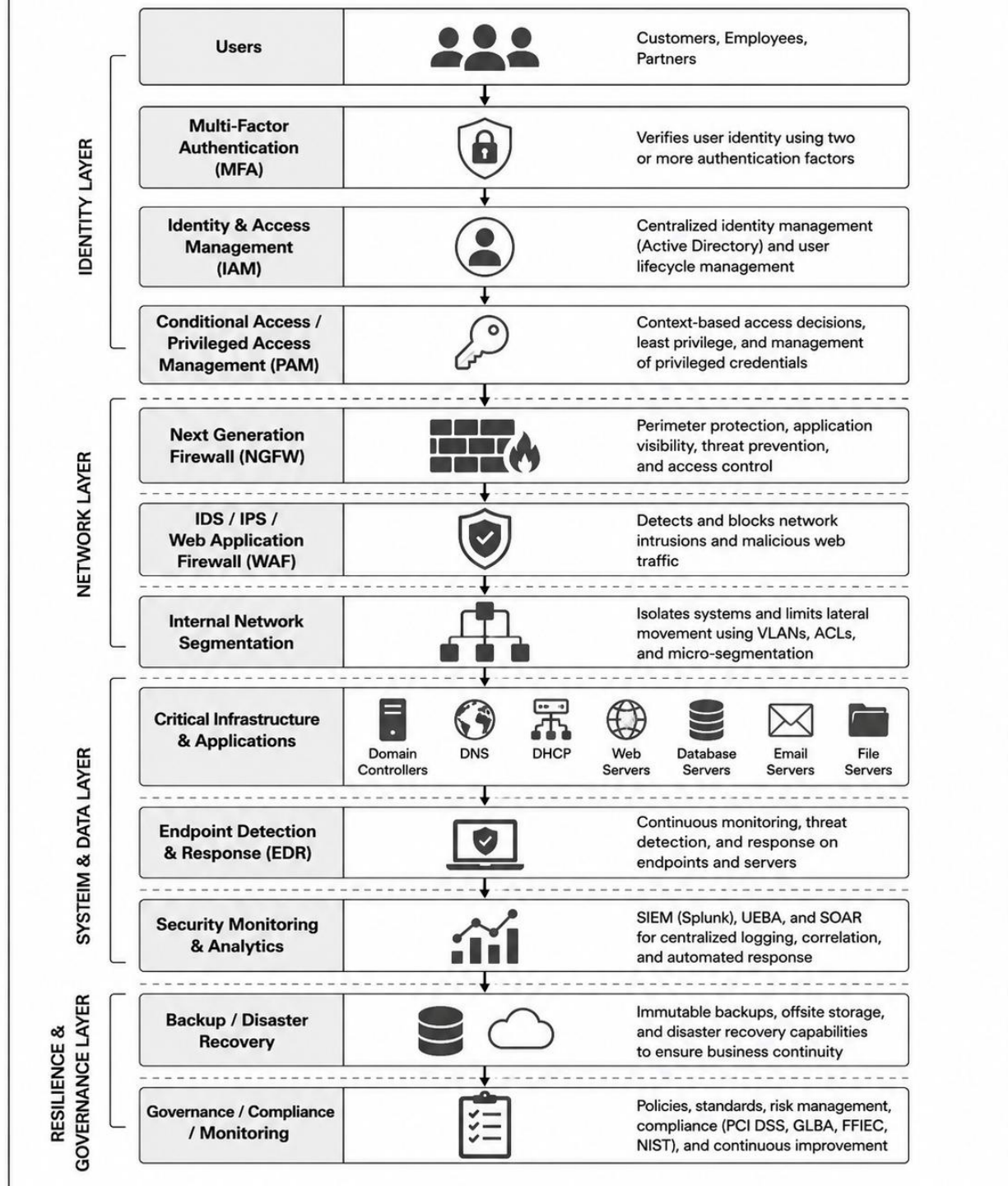


Figure 3-1 illustrates the proposed defense-in-depth architecture recommended for FICBANK based on Zero Trust principles and layered security controls (Rose et al., 2020; CISA, 2023).

Table 3-2. Core Components of FICBANK's Zero Trust Architecture

Security Layer	Primary Technologies	Security Objective
Identity	Active Directory, MFA, RBAC, PAM	Verify users and enforce least privilege
Device	Endpoint Detection and Response (EDR), Device Compliance	Ensure trusted and secure endpoints
Network	VLANs, Internal Firewalls, Network Access Control	Prevent unauthorized lateral movement
Application	Secure Authentication, Web Application Firewall (WAF)	Protect critical business applications
Data	Encryption, Data Loss Prevention (DLP), Secure Backups	Protect sensitive customer and financial information
Monitoring	Splunk Enterprise Security SIEM, UEBA, Threat Intelligence	Detect and respond to suspicious activity

Security Layer	Primary Technologies	Security Objective
Governance	Continuous Vulnerability Management, Compliance Monitoring	Maintain ongoing security maturity and regulatory alignment

The architectural components presented in *Table 3-2* collectively implement the core Zero Trust capabilities described in NIST SP 800-207 while supporting the identity, device, network, application, data, visibility, automation, and governance pillars identified within the CISA Zero Trust Maturity Model (Rose et al., 2020; CISA, 2023).

3.1.4 Expected Security Benefits

Implementing a Zero Trust Architecture provides FICBANK with significant operational and cybersecurity benefits. Continuous verification of users and devices reduces the likelihood of credential-based attacks, while network segmentation limits the ability of attackers to move laterally following an initial compromise. Centralized monitoring and behavioral analytics improve threat detection and incident response capabilities, enabling security personnel to identify malicious activity earlier in the attack lifecycle. Furthermore, the architecture strengthens the confidentiality, integrity, and availability of sensitive financial information by enforcing consistent security policies across users, devices, applications, and cloud-connected resources (NIST, 2020a).

From a business perspective, Zero Trust supports regulatory compliance by strengthening access governance, improving auditability, and reducing organizational exposure to operational,

financial, and reputational risk. The architecture also provides a scalable security foundation capable of supporting future digital transformation initiatives, hybrid-cloud adoption, and evolving cybersecurity threats without requiring significant redesign of the underlying security model (DoD, 2022; FFIEC, 2024).

3.1.5 Alignment with Industry Standards

The proposed Zero Trust implementation aligns with multiple internationally recognized cybersecurity frameworks and financial-sector security guidance, ensuring that FICBANK's modernization strategy reflects current industry best practices (NIST, 2020a; CISA, 2023).

Table 3-3. Zero Trust Alignment with Industry Standards

Framework / Standard	Alignment with Proposed Architecture
NIST SP 800-207	Establishes Zero Trust principles based on continuous verification and least privilege.
NIST SP 800-53 Rev. 5	Supports access control, system integrity, continuous monitoring, and risk management control families.
CISA Zero Trust Maturity Model	Aligns identity, device, network, application, data, visibility, automation, and governance pillars.
DoD Zero Trust Reference Architecture	Reinforces identity-centric security, micro-segmentation, and continuous authorization.

Framework / Standard	Alignment with Proposed Architecture
FFIEC Cybersecurity Guidance	Strengthens identity governance, network security, monitoring, and resilience for financial institutions.
GLBA Safeguards Rule	Enhances protection of customer financial information through layered administrative, technical, and physical safeguards.

Collectively, these frameworks provide complementary guidance supporting identity-centric security, continuous authorization, least-privilege access, security monitoring, and ongoing governance throughout the enterprise (DoD, 2022; FFIEC, 2024).

3.1.6 Implementation Considerations

Because Zero Trust affects multiple technology domains, implementation should follow a phased, risk-based approach that minimizes disruption to banking operations. Identity security enhancements such as Multi-Factor Authentication, Role-Based Access Control, and Privileged Access Management should be prioritized because they provide the foundation for subsequent network segmentation and conditional access policies. Once identity controls are established, FICBANK should implement internal network segmentation, centralized monitoring, endpoint detection capabilities, and continuous vulnerability management to complete the transition toward a mature Zero Trust environment (NIST, 2020a).

Executive sponsorship, user awareness, phased deployment, and continuous assessment will be essential to successful implementation. Regular security control assessments, authenticated vulnerability scans, configuration reviews, and security monitoring should be

performed to verify that the architecture continues to meet operational requirements and remains effective against evolving cyber threats. These validation activities will be described in detail in “Section 4: Test and Evaluation Plan”, ensuring that the effectiveness of each recommended control can be measured and continuously improved over time (NIST, 2022).

3.2 Network Segmentation and Internal Firewalls

3.2.1 Existing Network Risks

the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases identified several conditions indicating that FICBANK's existing network architecture provides insufficient internal protection against modern cyber threats. The vulnerability assessment identified exposed administrative services, including Server Message Block (SMB), Remote Desktop Protocol (RDP), and Secure Shell (SSH), that increased the organization's attack surface and creating opportunities for unauthorized access and privilege escalation through exposed administrative protocols and insufficient internal security boundaries (NIST, 2020a). Subsequent detective monitoring and forensic investigations identified reconnaissance activity, Shellshock exploitation attempts, malware staging, and suspicious administrative path discovery, demonstrating that threat actors may attempt to exploit exposed services and then move laterally across enterprise networks, making internal segmentation a critical component of modern cybersecurity architectures (Rose et al., 2020; CISA, 2023).

These findings suggest that FICBANK's previous network architecture relied too heavily on perimeter defenses while permitting excessive communication between internal systems. Once an attacker successfully compromises a single endpoint or administrative account, a flat

network architecture enables rapid lateral movement toward domain controllers, database servers, backup infrastructure, and other business-critical resources (DoD, 2022). For a financial institution responsible for protecting sensitive customer information, this level of implicit trust presents an unacceptable operational risk. Therefore, internal segmentation and policy-based traffic control should become foundational components of FICBANK's cybersecurity modernization strategy (NIST, 2020a).

3.2.2 Proposed Network Segmentation Strategy

To reduce the enterprise attack surface and contain malicious activity, FICBANK should redesign its network using a layered segmentation model aligned with Zero Trust security principles (Rose et al., 2020; CISA, 2023). Rather than allowing unrestricted communication across the internal network, access should be granted only where legitimate business requirements exist. This approach supports Zero Trust by replacing implicit trust with explicit authorization for every communication path.

The proposed architecture divides the enterprise into logical security zones, including an Internet edge protected by a Next-Generation Firewall (NGFW), a Demilitarized Zone (DMZ) hosting public-facing web services, an application tier, a protected database tier, an administrative management network, an endpoint user network, and a dedicated backup and recovery network (DoD, 2022). Communication between these zones should be governed by internal firewalls, VLANs, and access control policies that enforce least-privilege network access (NIST, 2020a).

Segmenting the network in this manner significantly limits the ability of attackers to move laterally after an initial compromise. For example, a compromised user workstation should not have direct access to database servers or Active Directory domain controllers. Instead, all communication should pass through controlled security boundaries where firewall policies, intrusion prevention systems, and continuous monitoring validate authorized traffic while blocking unauthorized connections (NIST, 2020a).

Figure 3-2. Proposed Secure Network Segmentation Model for FICBANK

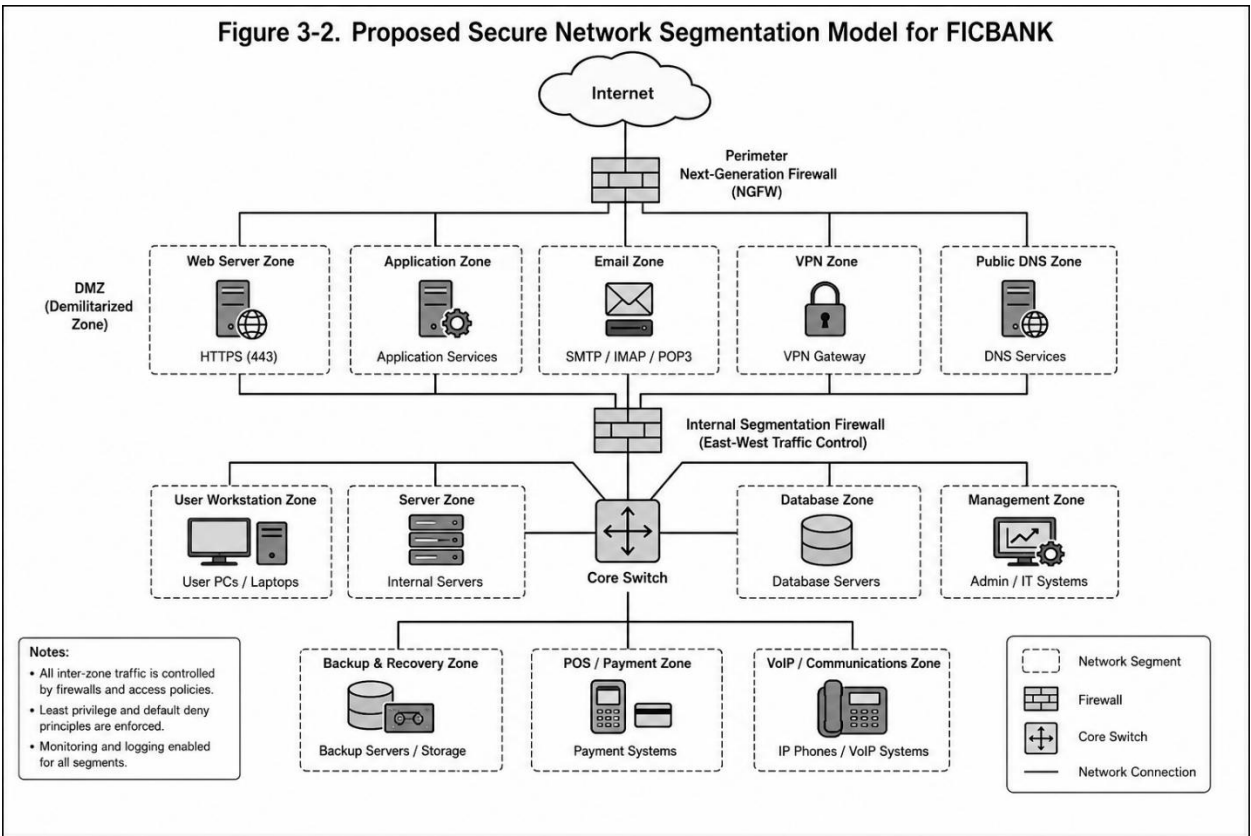


Figure 3-2 illustrates the proposed network segmentation architecture recommended for FICBANK. The design applies Zero Trust principles by separating enterprise resources into

logical security zones protected through internal firewalls, least-privilege communication policies, and continuous monitoring (Rose et al., 2020; DoD, 2022).

3.2.3 Internal Firewall Policies

Internal firewalls provide the enforcement mechanism for the proposed segmentation strategy by controlling communication between security zones. Unlike traditional perimeter firewalls that primarily inspect inbound and outbound Internet traffic, internal firewalls regulate east-west traffic, preventing unauthorized communication between internal systems and reducing the likelihood of attacker movement following a successful compromise (CISA, 2023).

FICBANK should adopt a default-deny firewall policy in which all inter-zone communication is blocked unless explicitly authorized for a documented business purpose. Firewall rules should be application-aware, permitting only required protocols and ports while logging all denied connections for security analysis (DoD, 2022). Administrative services such as RDP, SSH, SMB, LDAP, and PowerShell Remoting should be restricted to dedicated management networks and authorized administrators. User workstations should communicate only with approved business applications and should never have direct access to database servers or backup repositories (NIST, 2022).

These firewall policies improve both security and operational visibility by ensuring that unauthorized communication attempts generate audit records that can be correlated through Splunk Enterprise Security SIEM for investigation and response.

Table 3-4. Recommended Internal Firewall Rules

Source Zone	Destination Zone	Approved Service	Action	Business Justification
User Network	Web Application Servers	HTTPS (443)	Allow	Customer and employee application access
User Network	Database Servers	SQL	Deny	Prevent direct database access
User Network	Domain Controllers	LDAP/Kerberos (required authentication only)	Allow (restricted)	User authentication
Administrative Network	Domain Controllers	RDP, LDAP, Kerberos	Allow	Authorized system administration
Guest Wireless Network	Internal Corporate Network	Any	Deny	Isolate unmanaged devices
Backup Network	Production Servers	Backup protocols only	Allow	Scheduled backup operations

The firewall policy recommendations presented in *Table 3-4* enforce Zero Trust communication principles by allowing only explicitly authorized traffic between network segments while denying all unnecessary communication paths (Rose et al., 2020; NIST, 2020a).

3.2.4 East-West Traffic Protection

While perimeter firewalls protect the organization from external threats, many modern cyberattacks originate from compromised internal devices or stolen credentials (CISA, 2023). Consequently, FICBANK should implement additional controls specifically designed to protect east-west traffic between internal systems.

Recommended controls include internal intrusion detection and prevention systems (IDS/IPS), network access control (NAC), micro-segmentation for high-value assets, and continuous monitoring through Splunk Enterprise Security SIEM (DoD, 2022). Together, these technologies provide visibility into abnormal communication patterns, privilege escalation attempts, unauthorized administrative access, and lateral movement commonly associated with ransomware and advanced persistent threats.

Micro-segmentation should be applied to particularly sensitive environments, including Active Directory, financial databases, payment systems, and backup infrastructure. By isolating these assets behind dedicated security policies, FICBANK reduces the likelihood that compromise of a single endpoint will result in widespread enterprise disruption (CISA, 2023).

Table 3-5. Business Benefits of Network Segmentation

Security Improvement	Operational Benefit
Reduced lateral movement	Limits the spread of ransomware and malware

Security Improvement	Operational Benefit
Protected critical assets	Strengthens confidentiality of customer financial data
Controlled administrative access	Reduces insider and privileged account risk
Improved network visibility	Accelerates incident detection and forensic investigations
Segregated payment systems	Supports PCI DSS compliance objectives
Isolated backup environment	Improves ransomware recovery capability and business continuity

Collectively, these operational benefits demonstrate how network segmentation strengthens organizational resilience by limiting attacker movement, protecting sensitive financial information, and improving overall enterprise security posture (NIST, 2020a).

3.2.5 Expected Security Benefits

The proposed segmentation strategy significantly improves FICBANK's ability to protect critical business systems while maintaining operational efficiency. By enforcing logical trust boundaries, restricting administrative communications, and continuously monitoring traffic between security zones, the organization reduces opportunities for unauthorized access, privilege escalation, and ransomware propagation (NIST, 2020a).

From a business perspective, segmentation also improves regulatory readiness by supporting stronger access controls, simplifying compliance audits, and reducing the potential

operational impact of cybersecurity incidents. Combined with the Zero Trust principles established in Section 3.1, network segmentation forms the second foundational layer of FICBANK's defense-in-depth architecture and provides a scalable framework capable of supporting future cloud adoption and continued business growth (DoD, 2022; FFIEC, 2024).

3.2.6 Implementation Considerations

Implementation Factor	Recommendation
Priority	High: Addresses high-risk findings from the first three assessment phases involving exposed services and lateral movement.
Deployment Complexity	Moderate: Requires coordinated network redesign, firewall policy development, and testing.
Dependencies	Completion of foundational identity controls (Section 3.1) and network asset inventory.
Operational Impact	Temporary maintenance windows may be required during segmentation and firewall rule deployment.
Success Metrics	Reduced unrestricted inter-zone communication, successful firewall rule validation, elimination of unnecessary administrative exposure, and improved SIEM visibility into east-west traffic.

3.3 Identity and Access Management (IAM)

3.3.1 Current Identity Security Challenges

Identity has become the primary security perimeter for modern organizations, particularly financial institutions where users routinely access enterprise applications from multiple devices and locations. The cumulative cybersecurity assessments conducted throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases identified several conditions indicating that FICBANK's identity infrastructure requires significant strengthening. The Network and Vulnerability Assessment revealed exposed administrative services, including Remote Desktop Protocol (RDP), Secure Shell (SSH), and Server Message Block (SMB), that could be exploited through compromised credentials or excessive administrative privileges. The Security Monitoring Assessment and Incident and IOC Investigation phases further demonstrated reconnaissance activity, exploitation attempts, and malware staging behavior, emphasizing that attackers frequently target user identities and privileged accounts following a potential initial compromise.

These findings demonstrate that authentication alone is insufficient to protect critical banking systems. Financial institutions must continuously verify user identity, evaluate contextual risk, restrict administrative privileges, and maintain comprehensive visibility into authentication activities. Consequently, FICBANK should implement a modern Identity and Access Management (IAM) framework that integrates Multi-Factor Authentication (MFA), Role-Based Access Control (RBAC), Privileged Access Management (PAM), Conditional Access, and identity governance to reduce the likelihood of credential compromise, privilege escalation, and unauthorized access.

3.3.2 Multi-Factor Authentication (MFA)

Multi-Factor Authentication should serve as the first layer of identity protection for all employees, contractors, administrators, and remote users accessing FICBANK resources. Rather than relying solely on usernames and passwords, MFA requires users to provide multiple forms of authentication such as a password, a hardware token, biometric verification, or an authenticator application before access is granted. This additional verification significantly reduces the effectiveness of credential theft, password spraying, brute-force attacks, and phishing campaigns.

FICBANK should require MFA for privileged accounts, remote administrative sessions, cloud-based services, virtual private network (VPN) connections, and all applications processing sensitive financial information. Hardware security keys compliant with FIDO2 standards should be considered for highly privileged administrators because they provide strong protection against phishing-based credential theft. Conditional authentication policies should require additional verification whenever unusual login behavior, unmanaged devices, impossible travel events, or elevated risk scores are detected. These measures directly support the Zero Trust principle of continuously verifying user identity before granting access to enterprise resources.

3.3.3 Role-Based Access Control (RBAC)

Role-Based Access Control provides the authorization framework for enforcing the Principle of Least Privilege throughout FICBANK's enterprise environment. Rather than assigning permissions directly to individual users, RBAC groups permissions according to

business functions, ensuring employees receive only the minimum access necessary to perform their assigned responsibilities.

Administrative responsibilities should be separated from standard user activities through dedicated administrative accounts. Business units such as Finance, Human Resources, Customer Service, Information Technology, and Executive Leadership should each receive predefined access profiles aligned with operational requirements. Quarterly access reviews should verify that permissions remain appropriate as employee responsibilities change, reducing the risk associated with privilege accumulation and orphaned accounts. This structured authorization model strengthens governance while simplifying regulatory audits and access recertification activities.

Table 3-6. Example Role-Based Access Control Matrix

Role	Primary Systems	Authorized Privileges	Restrictions
Customer Service Representative	Customer Information System	Read, update customer records	No server or database administration
Financial Analyst	Financial Reporting Systems	Read financial data, generate reports	No Active Directory administration
System Administrator	Servers, Active Directory	System configuration and maintenance	Administrative actions logged and monitored

Role	Primary Systems	Authorized Privileges	Restrictions
Database Administrator	Database Servers	Database management	No unrestricted workstation administration
Security Operations Analyst	Splunk Enterprise Security, EDR	Monitor alerts, investigate incidents	No financial transaction processing

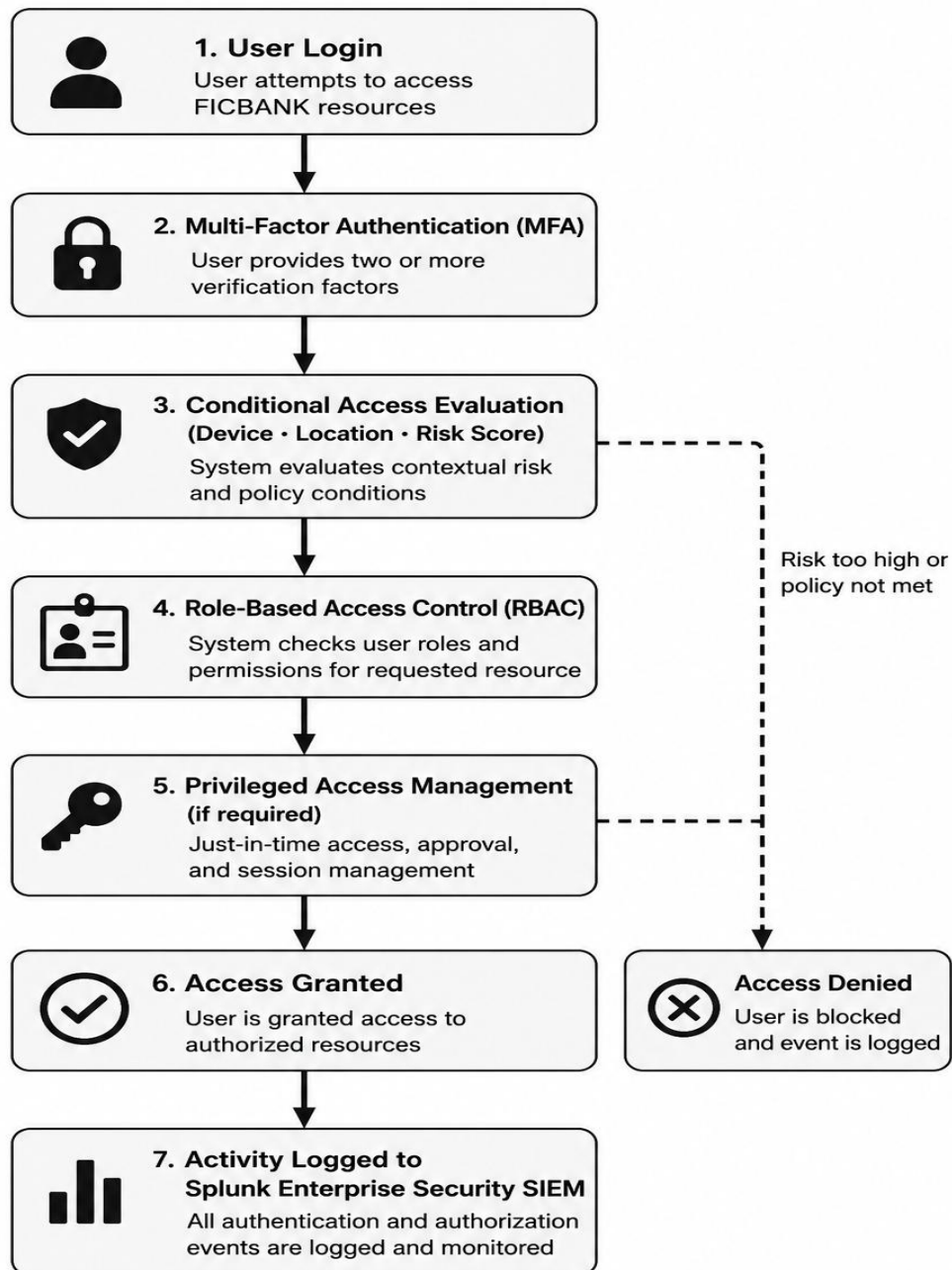
3.3.4 Privileged Access Management (PAM)

Privileged accounts present one of the highest risks within any enterprise because they possess extensive access to systems, applications, and sensitive data. If compromised, these accounts can enable attackers to disable security controls, access confidential information, create unauthorized accounts, and move laterally across the environment. To mitigate these risks, FICBANK should implement a centralized Privileged Access Management (PAM) solution that secures, monitors, and governs all privileged credentials.

The PAM solution should maintain privileged credentials within a secure encrypted vault, automatically rotate passwords after each administrative session, and enforce just-in-time (JIT) privilege elevation so that administrative rights are granted only for the duration of approved maintenance activities. All privileged sessions should be recorded, monitored, and integrated with Splunk Enterprise Security SIEM to support forensic investigations and compliance reporting. Administrative access should originate only from hardened Privileged Access Workstations (PAWs), minimizing the likelihood that privileged credentials are exposed through compromised user endpoints.

Figure 3-3. Identity Authentication and Authorization Workflow

Suggested diagram flow:



3.3.5 Identity Governance and Lifecycle Management

Identity governance ensures that user accounts remain accurate, authorized, and appropriately managed throughout their lifecycle. FICBANK should establish formal processes for account provisioning, modification, periodic review, and deprovisioning to reduce the likelihood of unauthorized access and dormant privileged accounts.

New user accounts should be created only following documented management approval and assignment of an appropriate business role. Access privileges should automatically adjust when employees transfer departments or assume new responsibilities. Upon termination or separation, all user accounts, privileged credentials, VPN access, and authentication tokens should be immediately revoked to prevent unauthorized access. Automated identity governance processes reduce administrative burden while supporting regulatory compliance and strengthening overall access control.

Table 3-7. Identity Security Control Mapping

Identity Control	Primary Threat Mitigated	Business Benefit
Multi-Factor Authentication	Credential theft, phishing	Stronger authentication assurance
Role-Based Access Control	Excessive privileges	Least privilege enforcement

Identity Control	Primary Threat Mitigated	Business Benefit
Privileged Access Management	Administrative account compromise	Improved governance and accountability
Conditional Access	Unauthorized remote access	Adaptive, risk-based authentication
Identity Lifecycle Management	Orphaned or inactive accounts	Improved operational security and compliance

3.3.6 Expected Security Benefits

Implementing a comprehensive Identity and Access Management framework significantly strengthens FICBANK's overall cybersecurity posture by reducing reliance on passwords alone and enforcing continuous verification of user identities. MFA, RBAC, PAM, and identity governance collectively reduce opportunities for credential compromise, privilege escalation, insider threats, and unauthorized administrative access. These controls also improve auditability, simplify compliance reporting, and enhance the organization's ability to detect suspicious authentication activity through centralized monitoring.

From a business perspective, stronger identity governance increases customer confidence, supports secure digital banking initiatives, and reduces operational risk associated with privileged accounts. Identity-centric security also provides the foundation for all remaining technical controls by ensuring that only authenticated and authorized users can access enterprise resources.

3.3.7 Implementation Considerations

Implementation Factor	Recommendation
Priority	High: Identity security is foundational to Zero Trust and directly addresses exposed administrative services identified in previous assessments.
Deployment Complexity	Moderate: Requires integration with Active Directory, cloud identity providers, and enterprise applications.
Dependencies	Zero Trust Architecture (Section 3.1) and Network Segmentation (Section 3.2).
Operational Impact	User training, phased MFA deployment, and periodic access reviews will be required to minimize operational disruption.
Success Metrics	100% MFA coverage for privileged accounts, quarterly access recertification, reduced privileged account exposure, and successful integration of identity events into Splunk Enterprise Security SIEM.

3.4 Splunk Enterprise Security Security Information and Event Management (SIEM)

3.4.1 Centralized Security Monitoring Challenges

The previous cybersecurity assessments demonstrated that although FICBANK generated valuable security logs across its infrastructure, the organization lacked a mature capability to

centrally collect, correlate, and analyze those events in real time. the Security Monitoring Assessment highlighted the importance of detective monitoring by identifying suspicious authentication attempts, abnormal network activity, and indicators of compromise that required manual analysis before security personnel could determine their significance. the Incident and IOC Investigation further demonstrated that malware staging, reconnaissance activity, and exploitation attempts can occur rapidly and often leave evidence distributed across multiple systems rather than within a single device or application. These observations emphasize that effective cybersecurity depends not only on preventive controls but also on continuous visibility into enterprise activity, allowing security personnel to identify malicious behavior across multiple systems before it escalates into a significant cybersecurity incident. incident.

Without centralized monitoring, security analysts must manually review logs from firewalls, servers, endpoints, authentication services, and network devices, increasing the likelihood that malicious activity will remain undetected (NIST, 2020a). Delayed detection extends attacker dwell time, allowing adversaries to escalate privileges, move laterally, exfiltrate sensitive information, or deploy ransomware before incident responders recognize the compromise (NIST, 2022). For a financial institution responsible for safeguarding customer information and maintaining uninterrupted banking operations, delayed detection presents substantial operational, regulatory, and reputational risk.

3.4.2 Splunk Enterprise Security Architecture

To strengthen enterprise visibility, FICBANK should implement Splunk Enterprise Security (ES) as its centralized Security Information and Event Management (SIEM) platform.

Splunk ES provides a unified environment for collecting, normalizing, correlating, and analyzing security events generated throughout the enterprise (NIST, 2022). Rather than evaluating individual log sources independently, the SIEM aggregates information from servers, endpoints, Active Directory, firewalls, intrusion detection systems, endpoint protection platforms, cloud services, databases, and network devices to produce a comprehensive view of organizational security.

Within the proposed architecture, Splunk ES functions as the analytical core of FICBANK's defense-in-depth strategy. Security events generated by identity systems, network infrastructure, endpoint agents, vulnerability scanners, and cloud services are continuously forwarded to the SIEM, where correlation searches identify suspicious behavior based on predefined detection rules and behavioral analytics (NIST, 2022). High-confidence alerts automatically generate incidents for investigation by the Security Operations Center (SOC), enabling analysts to rapidly determine attack scope, affected systems, and recommended response actions (FFIEC, 2024).

This centralized architecture significantly improves visibility while supporting the Zero Trust principles established earlier in this report by continuously validating security events rather than relying solely on preventive technologies.

Figure 3-4. Splunk Enterprise Security Monitoring Architecture

Figure 3-4. Splunk Enterprise Security Monitoring Architecture

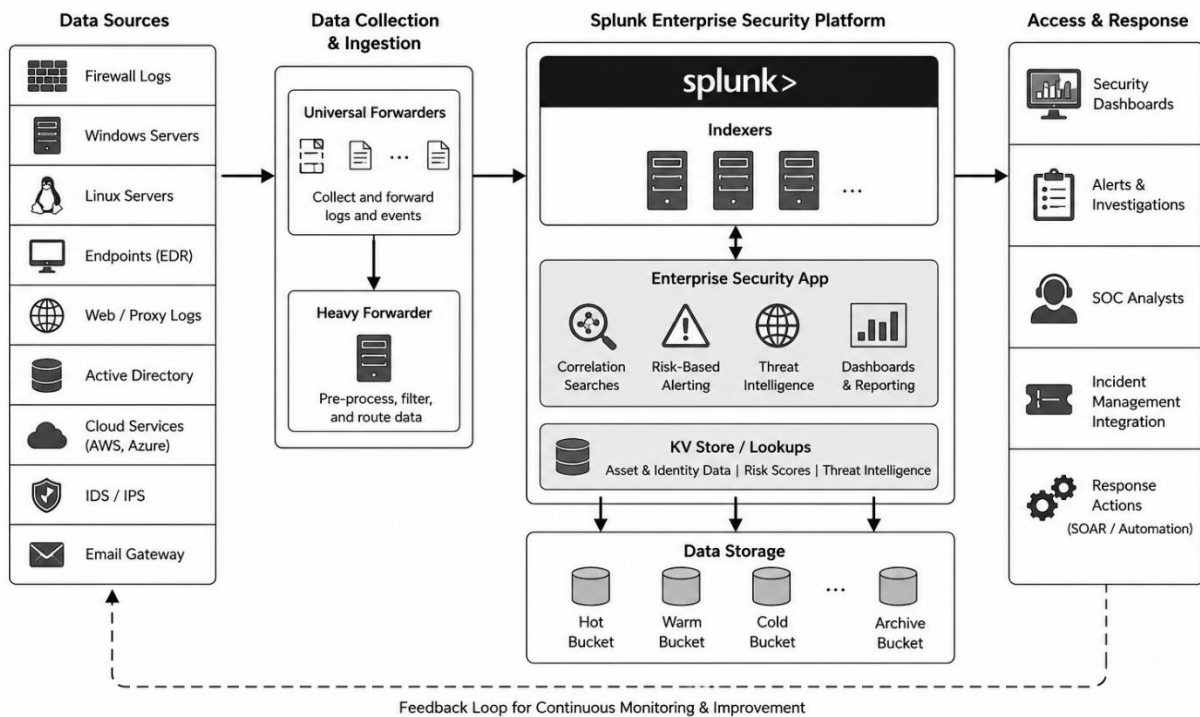


Figure 3-4 illustrates the centralized monitoring architecture proposed for FICBANK. Enterprise security telemetry is aggregated from identity services, endpoints, firewalls, servers, cloud resources, and network devices to support continuous monitoring, event correlation, and timely incident response consistent with NIST continuous monitoring principles (NIST, 2020a; CISA, 2023).

3.4.3 Security Event Correlation and Threat Detection

The primary advantage of Splunk Enterprise Security is its ability to correlate seemingly unrelated security events into meaningful attack patterns. Rather than generating isolated alerts

for individual failed logins or firewall denials, the SIEM combines events across multiple systems to identify coordinated malicious activity (NIST, 2020a).

For example, repeated failed authentication attempts against Active Directory followed by successful VPN authentication from an unfamiliar geographic location and privileged PowerShell execution may indicate a compromised administrative account (NIST, 2022). Similarly, reconnaissance activity observed by intrusion detection systems followed by suspicious endpoint behavior and unauthorized database access may represent lateral movement preceding data exfiltration.

To improve detection accuracy and reduce alert fatigue, FICBANK should implement Risk-Based Alerting (RBA) within Splunk Enterprise Security (CISA, 2023). Instead of relying solely on static alert thresholds, RBA assigns cumulative risk scores to users, systems, and activities. Individual events that appear benign when viewed independently become high-priority incidents when correlated with other suspicious behaviors. This approach enables analysts to prioritize investigations according to organizational risk rather than alert volume (FFIEC, 2024).

Table 3-8. Recommended Enterprise Log Sources

Log Source	Security Value	Example Detection Use Cases
Active Directory	User authentication and privilege changes	Account compromise, privilege escalation

Log Source	Security Value	Example Detection Use Cases
Next-Generation Firewalls	Network traffic and policy enforcement	Unauthorized connections, blocked attacks
IDS/IPS	Intrusion detection	Exploitation attempts, reconnaissance
Endpoint Detection and Response	Endpoint telemetry	Malware execution, ransomware activity
VPN Gateway	Remote access activity	Suspicious remote logins, impossible travel
Windows Servers	Administrative events	Service modification, PowerShell execution
Linux Servers	System authentication and privilege usage	Unauthorized SSH access
Vulnerability Scanners	Security posture	Newly discovered vulnerabilities
Cloud Services	Identity and API activity	Excessive permissions, cloud misuse

The enterprise log sources summarized in *Table 3-8* provide comprehensive visibility across users, endpoints, applications, network infrastructure, and cloud services, enabling centralized monitoring and event correlation throughout the enterprise (NIST, 2020a).

3.4.4 Security Operations and Incident Response Integration

A mature SIEM extends beyond event collection by supporting coordinated incident response activities. Splunk Enterprise Security should integrate with FICBANK's incident response procedures to automatically generate investigations when high-risk alerts occur (NIST, 2020a). Automated workflows can notify the Security Operations Center, create incident tickets, preserve forensic evidence, and initiate predefined containment actions while maintaining detailed audit records (NIST, 2022).

Integration with Endpoint Detection and Response platforms further enhances response capabilities by enabling analysts to isolate compromised endpoints, terminate malicious processes, collect forensic artifacts, and prevent additional malware execution directly from the SIEM interface (CISA, 2023). These automated workflows reduce response times while improving consistency and supporting regulatory reporting requirements.

Table 3-9. Example High-Priority Correlation Rules

Correlation Rule	Trigger Condition	Recommended Automated Response
Excessive Failed Authentication	Multiple failed logins followed by successful authentication	Notify SOC and require MFA verification

Correlation Rule	Trigger Condition	Recommended Automated Response
Privileged Account Misuse	Administrative login outside normal business hours	Generate high-priority investigation
Malware Detection	EDR detects malicious executable	Isolate endpoint and notify incident responders
Lateral Movement Indicators	SMB/RDP connections across multiple VLANs	Generate critical alert and review firewall logs
Multiple Critical Vulnerabilities	Vulnerability scan identifies exploitable systems	Create remediation ticket and notify system owners

The correlation rules presented in *Table 3-9* illustrate how automated detection logic can prioritize high-risk security events while supporting timely investigation and coordinated incident response activities (NIST, 2022).

3.4.5 Compliance Reporting and Operational Benefits

Beyond threat detection, Splunk Enterprise Security supports FICBANK's governance and compliance objectives by maintaining centralized audit logs, generating executive dashboards, and providing evidence for regulatory examinations (FFIEC, 2024). Automated reporting simplifies compliance with financial-sector requirements by demonstrating that

security events are continuously monitored, investigated, and retained according to organizational policy (NIST, 2020a).

Operationally, centralized monitoring reduces analyst workload by consolidating information from numerous security technologies into a single analytical platform. Executives benefit from improved visibility through dashboards that summarize security trends, incident metrics, vulnerability status, and organizational risk. These capabilities improve strategic decision-making while supporting continuous cybersecurity improvement (CISA, 2023).

3.4.6 Implementation Considerations

Implementation Factor	Recommendation
Priority	High: Continuous monitoring is essential for detecting attacks identified during The Security Monitoring Assessment and Incident and IOC Investigation phases.
Deployment Complexity	Moderate to High: Requires integration of enterprise log sources, correlation rules, and SOC procedures.
Dependencies	Zero Trust Architecture (Section 3.1), Network Segmentation (Section 3.2), and Identity & Access Management (Section 3.3).
Operational Impact	Initial tuning of correlation rules and analyst training will be required to minimize false positives and maximize detection accuracy.

Implementation Factor	Recommendation
Success Metrics	Reduced Mean Time to Detect (MTTD), reduced Mean Time to Respond (MTTR), increased log source coverage, improved alert fidelity, and successful execution of automated response workflows.

3.5 Endpoint Detection and Response (EDR)

3.5.1 Endpoint Threat Landscape

Endpoints represent one of the most frequently targeted attack surfaces because they routinely process sensitive financial information while providing users with direct access to enterprise applications, cloud resources, and critical business systems (NIST, 2020a). Employee workstations, laptops, virtual desktops, and servers routinely process sensitive financial information while providing access to internal applications, cloud services, and administrative systems. Consequently, attackers often target endpoints through phishing campaigns, malicious attachments, drive-by downloads, credential theft, ransomware, and exploitation of unpatched software vulnerabilities.

The cybersecurity assessments conducted throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases demonstrated that FICBANK faces many of these risks. The Network and Vulnerability Assessment identified exposed administrative services that could facilitate unauthorized remote access if attacker-controlled endpoints successfully authenticated to enterprise systems. The Security Monitoring Assessment and Incident and IOC Investigation phases further identified

reconnaissance activity, Shellshock exploitation attempts, malware staging behavior, and suspicious administrative commands that illustrate how compromised endpoints can become launch points for privilege escalation, lateral movement, and ransomware deployment. These findings demonstrate that traditional signature-based antivirus solutions alone cannot adequately defend against sophisticated attacks that employ fileless malware, living-off-the-land techniques, or zero-day exploits. FICBANK therefore requires a modern Endpoint Detection and Response platform capable of continuously monitoring endpoint activity, detecting malicious behavior, and rapidly containing compromised devices before attacks spread throughout the enterprise.

3.5.2 Endpoint Detection and Response Deployment Strategy

FICBANK should deploy an enterprise-grade Endpoint Detection and Response solution across all Windows and Linux servers, employee workstations, executive devices, administrative workstations, and cloud-hosted virtual machines (NIST, 2020a). The EDR platform should operate continuously by collecting telemetry related to running processes, command-line execution, user authentication, registry modifications, network connections, file system activity, PowerShell execution, and memory utilization.

Unlike traditional antivirus software that primarily relies on malware signatures, EDR continuously evaluates endpoint behavior to identify suspicious activities that may indicate compromise. Machine learning, behavioral analytics, and threat intelligence should be leveraged to detect ransomware encryption activity, privilege escalation, unauthorized PowerShell execution, credential dumping, persistence mechanisms, malicious scripting, and lateral movement techniques commonly associated with advanced persistent threats (NIST, 2022).

To maximize effectiveness, the EDR platform should integrate with Active Directory, Microsoft Defender for Identity (or an equivalent identity protection solution), vulnerability management tools, and Splunk Enterprise Security SIEM (CISA, 2023). This integration enables endpoint events to be correlated with authentication activity, firewall logs, vulnerability data, and network telemetry, providing security analysts with comprehensive visibility into attack progression throughout the enterprise (DoD, 2022).

Figure 3-5. Endpoint Detection and Response Workflow

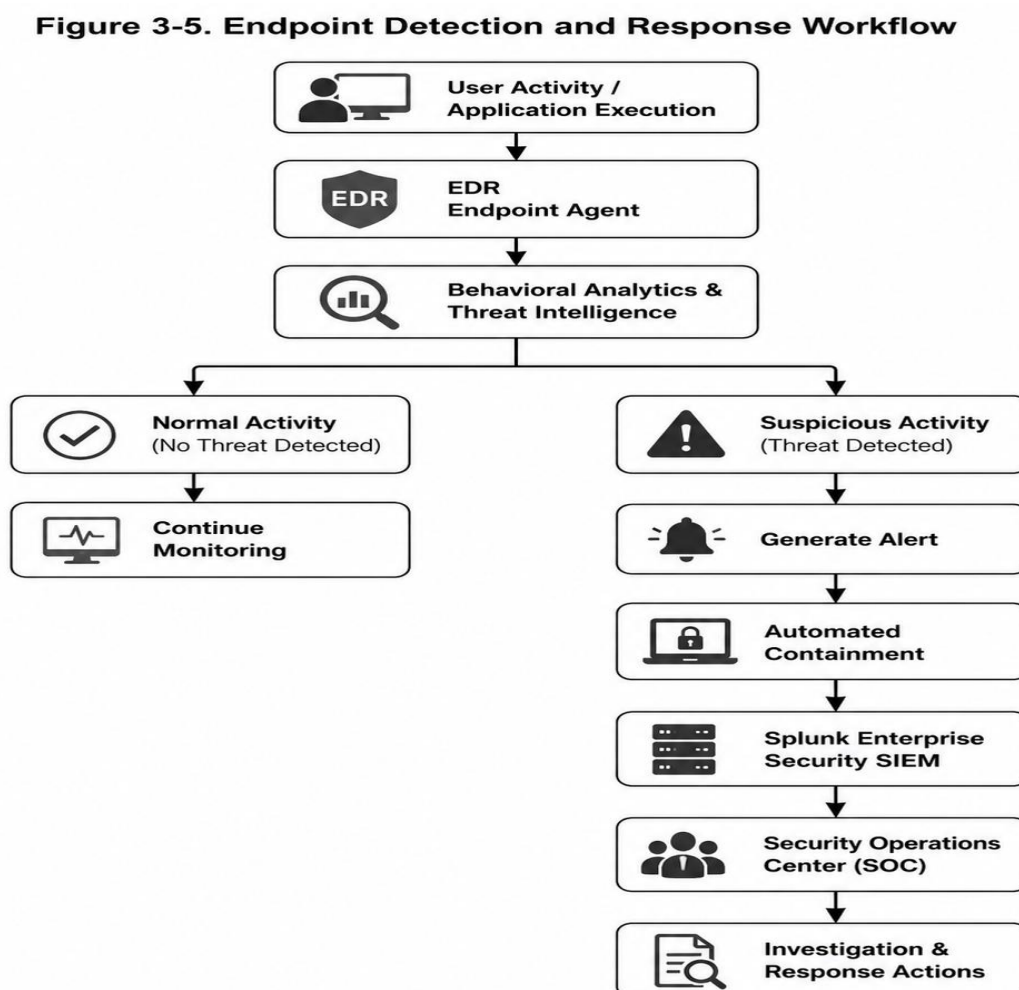


Figure 3-5 illustrates the proposed Endpoint Detection and Response workflow for FICBANK. Endpoint telemetry is continuously analyzed to identify suspicious behavior, automate containment actions, and provide centralized visibility through Splunk Enterprise Security SIEM, thereby supporting continuous monitoring and Zero Trust security objectives (NIST, 2020a; CISA, 2023).

3.5.3 Behavioral Detection and Threat Hunting

A primary advantage of Endpoint Detection and Response is its ability to identify malicious behavior that may not yet have a known malware signature. Instead of focusing solely on malicious files, EDR continuously evaluates behavioral indicators associated with attacker techniques documented in frameworks such as the MITRE ATT&CK framework (NIST, 2020a).

Examples of behavioral indicators that should trigger investigation include:

- PowerShell execution from unusual user accounts.
- Credential dumping attempts targeting LSASS memory.
- Unauthorized creation of scheduled tasks or persistence mechanisms.
- Execution of unsigned administrative tools.
- SMB or RDP connections inconsistent with normal business operations.
- Large-scale file encryption indicative of ransomware activity.
- Unexpected outbound communications with known malicious infrastructure.

Security analysts should perform proactive threat hunting using historical endpoint telemetry to identify suspicious activity that automated detection rules may not immediately classify as malicious. Threat hunting improves organizational resilience by enabling analysts to discover stealthy attacker behavior before significant damage occurs (NIST, 2020a).

Table 3-10. Common Endpoint Threats and EDR Detection Capabilities

Threat	Typical Attack Technique	EDR Detection Capability
Ransomware	File encryption, privilege escalation	Behavioral ransomware detection and automated isolation
Credential Theft	LSASS memory access, pass-the-hash	Credential dumping detection
Fileless Malware	PowerShell, WMI, scripting	Script monitoring and behavioral analytics
Remote Access Trojans	Persistent command-and-control	Network connection monitoring
Insider Threats	Unauthorized file access	User behavior analytics
Lateral Movement	SMB, RDP, PsExec	Remote administration monitoring

Table 3-10 demonstrates how behavioral monitoring extends endpoint protection beyond traditional signature-based malware detection by identifying malicious activities that commonly precede enterprise compromise (NIST, 2020a).

3.5.4 Automated Response and Incident Containment

Rapid containment is essential for minimizing the operational impact of cybersecurity incidents. Once suspicious endpoint behavior exceeds predefined risk thresholds, the EDR platform should automatically execute predefined response actions to prevent further attacker activity while preserving forensic evidence (NIST, 2020a).

Recommended automated response actions include:

- Isolating compromised endpoints from the corporate network.
- Terminating malicious processes.
- Quarantining suspicious files.
- Blocking malicious hashes across the enterprise.
- Suspending compromised user sessions.
- Triggering automated alerts within Splunk Enterprise Security SIEM.
- Collecting forensic artifacts, including memory captures and process trees, for incident investigation.

These automated capabilities reduce Mean Time to Respond (MTTR) while improving consistency across incident response activities. Security analysts retain authority to release isolated devices after remediation and validation activities are complete (NIST, 2020a).

Table 3-11. Recommended Automated EDR Response Actions

Detection Event	Recommended Automated Response	Security Objective
Malware execution	Quarantine file and isolate endpoint	Prevent malware propagation
Credential dumping	Terminate process and notify SOC	Protect privileged credentials
Ransomware behavior	Disconnect endpoint from network	Contain encryption activity
Suspicious PowerShell execution	Generate high-priority alert	Investigate potential compromise
Unauthorized administrative tools	Block execution and preserve evidence	Prevent privilege escalation
Multiple high-risk detections	Escalate incident to SOC	Coordinate enterprise response

The automated response actions presented in *Table 3-11* support rapid containment, forensic preservation, and coordinated incident response while minimizing the operational impact of cybersecurity incidents (NIST, 2022).

3.5.5 Expected Security Benefits

Deploying Endpoint Detection and Response significantly improves FICBANK's ability to detect, investigate, and contain sophisticated attacks before they impact critical business operations. Continuous behavioral monitoring reduces reliance on traditional antivirus signatures while improving visibility into endpoint activity across workstations, servers, and cloud-hosted

systems (NIST, 2020a). Integration with Splunk Enterprise Security SIEM further strengthens enterprise-wide situational awareness by correlating endpoint telemetry with authentication events, firewall logs, vulnerability data, and network traffic (CISA, 2023).

From a business perspective, EDR enhances operational resilience by minimizing downtime associated with ransomware, reducing incident response costs, and protecting customer financial information from unauthorized disclosure. Automated containment capabilities also support regulatory compliance by demonstrating that FICBANK can rapidly identify and respond to cybersecurity incidents while maintaining comprehensive audit records for forensic investigations and regulatory examinations (FFIEC, 2024).

3.5.6 Implementation Considerations

Implementation Factor	Recommendation
Priority	High: Directly addresses malware, ransomware, and endpoint compromise identified during previous assessments.
Deployment Complexity	Moderate: Requires enterprise-wide agent deployment, policy tuning, and SIEM integration.
Dependencies	Zero Trust Architecture (Section 3.1), Identity and Access Management (Section 3.3), and Splunk Enterprise Security SIEM (Section 3.4).
Operational Impact	Pilot deployment and phased rollout should be performed to validate policies and minimize disruption to business operations.

Implementation Factor	Recommendation
Success Metrics	100% endpoint coverage, reduced Mean Time to Detect (MTTD), reduced Mean Time to Respond (MTTR), increased automated containment success, and successful integration of endpoint telemetry into Splunk Enterprise Security SIEM.

3.6.3 Secure Patch Management and Configuration Governance

Patch management should operate as a structured governance process rather than a routine administrative activity (AWS, 2023). Security updates should first be evaluated within a controlled testing environment to verify compatibility with enterprise applications, authentication services, financial systems, and operational workflows before deployment to production environments. This phased approach minimizes operational disruption while ensuring that critical security updates are implemented in a timely and controlled manner.

In addition to software updates, FICBANK should establish secure configuration baselines using recognized industry guidance, including the Center for Internet Security (CIS) Benchmarks and applicable Security Technical Implementation Guides (STIGs). Configuration management should address password policies, unnecessary services, remote administration protocols, encryption settings, logging configurations, and operating system hardening. Standardized configuration baselines reduce security inconsistencies across enterprise systems while simplifying compliance verification and ongoing maintenance (DoD, 2022).

Automated patch deployment technologies should be used wherever practical to improve consistency, reduce administrative effort, and accelerate remediation of newly disclosed vulnerabilities. Emergency patch procedures should also be established for vulnerabilities subject to active exploitation, enabling FICBANK to respond rapidly when significant threats emerge (NIST, 2020a).

Figure 3-6. Enterprise Vulnerability Management and Patch Governance Lifecycle

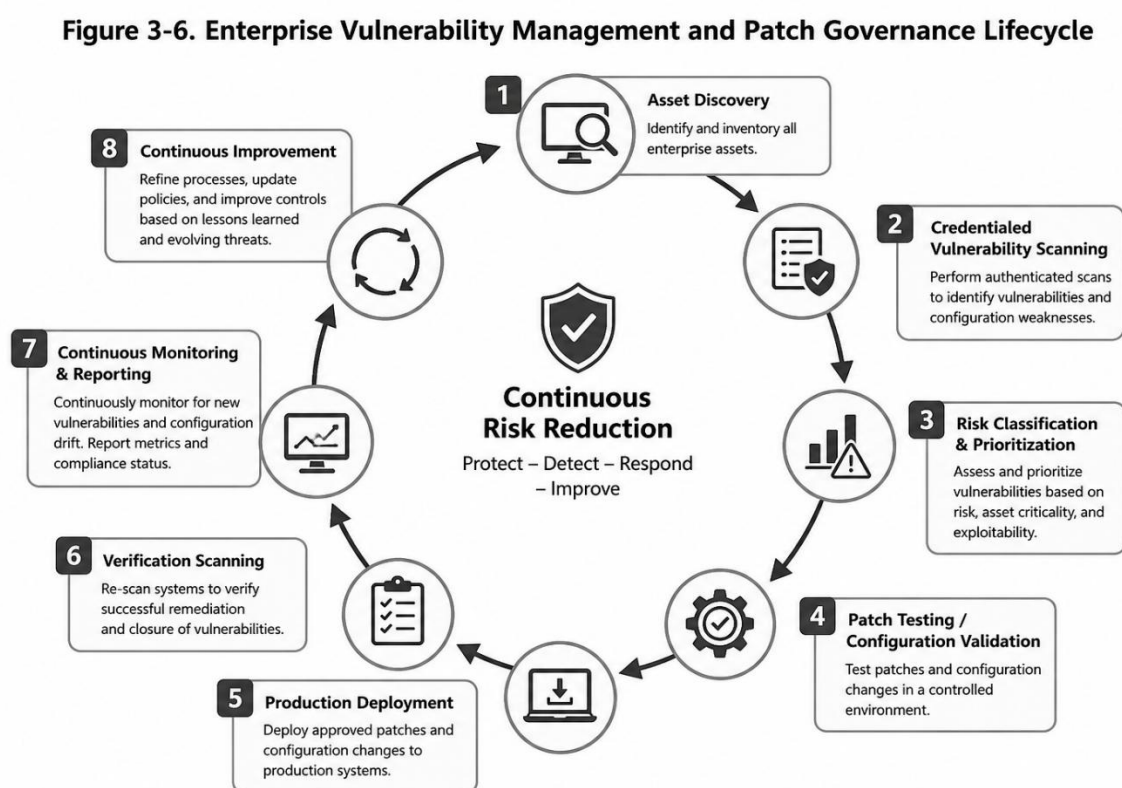


Figure 3-6 illustrates the enterprise vulnerability management lifecycle recommended for FICBANK. The lifecycle integrates continuous asset discovery, authenticated vulnerability scanning, risk prioritization, patch governance, verification scanning, and ongoing monitoring to support continuous cybersecurity improvement (NIST, 2022; AWS, 2023).

3.6.4 Continuous Validation and Compliance Monitoring

Successful vulnerability management extends beyond deploying software updates. FICBANK should verify the effectiveness of remediation activities through follow-up authenticated scans, configuration assessments, and compliance validation exercises. Verification scanning confirms that vulnerabilities have been successfully remediated while identifying unsuccessful deployments or configuration drift that may require additional corrective action (NIST, 2022).

Continuous monitoring should also measure compliance with established security baselines and organizational service-level objectives. Executive dashboards generated through Splunk Enterprise Security SIEM and vulnerability management platforms should summarize remediation performance, outstanding vulnerabilities, system compliance, and historical trends. These metrics enable executive leadership to evaluate organizational security maturity while supporting regulatory examinations and internal governance activities (CISA, 2023).

Periodic independent assessments should validate adherence to NIST SP 800-53 Rev. 5 security controls, CIS Benchmarks, PCI DSS requirements, FFIEC guidance, and the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule. Continuous validation ensures that implemented controls remain effective as technology environments evolve and new vulnerabilities emerge (NIST, 2020a).

Table 3-13. Enterprise Vulnerability Management Governance Process

Program Activity	Primary Objective	Expected Outcome
Asset Inventory	Maintain visibility of enterprise assets	Complete and current asset catalog
Credentialed Vulnerability Scanning	Identify vulnerabilities and configuration weaknesses	Accurate assessment of enterprise risk
Risk Prioritization	Focus remediation on highest-risk findings	Efficient allocation of remediation resources
Patch Testing	Validate update compatibility	Reduced operational disruption
Production Deployment	Implement approved security updates	Reduced exposure to exploitable vulnerabilities
Verification Scanning	Confirm successful remediation	Continuous improvement and reduced residual risk
Executive Reporting	Communicate security posture and trends	Improved governance and informed decision-making

The governance process summarized in *Table 3-13* establishes a repeatable vulnerability management lifecycle that supports continuous risk reduction, regulatory compliance, and long-term cybersecurity maturity (NIST, 2020a; CISA, 2023).

3.6.5 Expected Security Benefits

Implementing a comprehensive vulnerability management and patch governance program enables FICBANK to proactively reduce cybersecurity risk by identifying and remediating exploitable weaknesses before they can be leveraged by attackers (NIST, 2020a). Continuous assessment, authenticated scanning, standardized configuration management, and risk-based remediation significantly reduce the organization's exposure to ransomware, privilege escalation, remote code execution, and other common attack techniques (AWS, 2023).

From a business perspective, structured patch governance improves operational stability by reducing emergency maintenance activities, strengthening regulatory compliance, and providing executive leadership with measurable insight into organizational security maturity. Integration with Splunk Enterprise Security SIEM, Endpoint Detection and Response, and the broader Zero Trust architecture further enhances enterprise visibility by correlating vulnerability data with real-time security events and enabling risk-informed decision-making across the organization (CISA, 2023).

3.6.6 Implementation Considerations

Implementation Factor	Recommendation
Priority	High: Directly addresses credentialed scanning limitations and exploitation attempts identified during previous assessments.
Deployment Complexity	Moderate: Requires integration of vulnerability scanners, asset inventory, patch management platforms, and configuration baselines.

Implementation Factor	Recommendation
Dependencies	Zero Trust Architecture (Section 3.1), Splunk Enterprise Security SIEM (Section 3.4), Endpoint Detection and Response (Section 3.5), and enterprise asset inventory.
Operational Impact	Routine maintenance windows, change management procedures, and user communication will be required to minimize disruption during patch deployment.
Success Metrics	Increased authenticated scan coverage, reduced remediation timelines for critical vulnerabilities, improved CIS/STIG compliance, successful verification scans, and measurable reductions in enterprise vulnerability exposure.

4. Test and Evaluation Plan

4.1 Test and Evaluation Objectives

Successful implementation of cybersecurity controls requires more than deploying security technologies; organizations must also verify that those controls operate effectively under normal operating conditions and continue to provide the intended level of protection as organizational technologies, operational requirements, and cyber threats evolve (NIST, 2022). Consistent with the guidance provided in NIST Special Publication 800-53A Revision 5, this Test and Evaluation Plan establishes a structured methodology for validating the effectiveness of the technical controls recommended throughout Section 3 (NIST, 2020a). The objective is to

provide FICBANK with a repeatable process for determining whether implemented safeguards adequately protect organizational assets, reduce identified risks, and support regulatory compliance.

The validation activities described in this section evaluate the effectiveness of the proposed Zero Trust Architecture, Network Segmentation and Internal Firewalls, Identity and Access Management, Splunk Enterprise Security SIEM, Endpoint Detection and Response, and Vulnerability Management and Patch Governance controls. Testing focuses on verifying that security controls are properly configured, operate as intended, produce expected security outcomes, and continue to support FICBANK's business operations without introducing unacceptable operational risk (NIST, 2022).

Consistent with NIST SP 800-53A, three complementary assessment methods will be used throughout the validation process:

- **Examine:** Review policies, procedures, system configurations, firewall rules, architecture diagrams, vulnerability reports, and audit logs.
- **Interview:** Interview system administrators, security analysts, and operational personnel to verify that security procedures are consistently followed.
- **Test:** Perform technical validation activities, including authenticated vulnerability scanning, authentication testing, firewall rule verification, endpoint simulations, log correlation validation, and disaster recovery exercises.

When executed after implementation, these assessment methods can provide evidence that implemented controls satisfy organizational security objectives while supporting continuous improvement and ongoing risk management. These three assessment methods are defined by

NIST Special Publication 800-53A Revision 5 and provide complementary evidence regarding the effectiveness of implemented security controls (NIST, 2022).

4.2 Security Control Validation Strategy

Rather than independent technology evaluation, FICBANK should validate controls according to their contribution to the overall defense-in-depth architecture (NIST, 2020a). Because the recommended controls operate together, successful validation requires confirming both individual effectiveness and interoperability between related security technologies.

Table 4-1. Security Control Validation Strategy

Security Control	Primary Validation Activity	Assessment Method (NIST SP 800-53A)	Expected Outcome
Zero Trust Architecture	Verify continuous authentication, segmentation, and policy enforcement	Examine, Test	Unauthorized users and devices are denied access
Network Segmentation & Internal Firewalls	Validate VLAN boundaries and firewall rules	Examine, Test	Unauthorized east-west traffic is blocked

Security Control	Primary Validation Activity	Assessment Method (NIST SP 800-53A)	Expected Outcome
Identity & Access Management	Test MFA, RBAC, PAM, and Conditional Access	Examine, Interview, Test	Access granted only to authorized users
Splunk Enterprise Security SIEM	Validate log collection, correlation rules, and alert generation	Examine, Test	Security events detected and correlated accurately
Endpoint Detection & Response	Execute endpoint attack simulations	Test	Malicious behavior detected and contained
Vulnerability Management & Patch Governance	Perform authenticated vulnerability scans and remediation verification	Examine, Test	Critical vulnerabilities identified and remediated within defined timelines

The validation strategy presented in *Table 4-1* demonstrates how each recommended technical control can be assessed using structured NIST assessment procedures while ensuring that integrated security capabilities function collectively rather than independently (NIST, 2022).

4.3 Zero Trust Architecture Validation

Implementation of the Zero Trust Architecture should be validated by confirming that all access requests are continuously evaluated according to user identity, device compliance,

authentication strength, and authorization policies (Rose et al., 2020). Testing should verify that unmanaged devices, unauthorized users, and accounts lacking Multi-Factor Authentication cannot access protected enterprise resources.

Additional validation activities should confirm that administrative sessions originate only from approved management workstations, privileged access requires appropriate authorization, and network segmentation policies enforce communication boundaries established within the proposed architecture (CISA, 2023). Authentication logs should be reviewed to verify successful enforcement of Conditional Access policies and continuous monitoring of privileged activities.

4.4 Network Segmentation and Firewall Validation

Network segmentation should be validated through controlled connectivity testing between enterprise security zones (NIST, 2022). Security assessors should confirm that communication between user networks, administrative networks, database servers, backup infrastructure, and public-facing systems complies with approved firewall policies.

Firewall rule validation should include verification of default-deny policies, application-specific filtering, logging of denied connections, and protection of administrative protocols such as RDP, SSH, and SMB. Simulated lateral movement exercises should verify that unauthorized communications are blocked while legitimate business applications continue operating without interruption (Rose et al., 2020).

Table 4-2. Network Validation Activities

Validation Activity	Expected Result
User VLAN attempts direct database access	Connection denied
Guest wireless attempts internal access	Blocked
Administrative workstation connects to Domain Controller	Authorized access permitted
Simulated lateral movement	Internal firewall blocks unauthorized communication
Firewall logging verification	All denied connections recorded in Splunk SIEM

The validation activities summarized in *Table 4-2* confirm that network segmentation and firewall policies effectively enforce communication boundaries while supporting Zero Trust principles and defense-in-depth (NIST, 2022).

4.5 Identity and Access Management Validation

Identity validation activities should verify that Multi-Factor Authentication, Role-Based Access Control, Privileged Access Management, and identity governance operate together as intended (CISA, 2023). Security assessors should attempt authentication using accounts with different privilege levels to confirm that access decisions align with documented authorization policies.

Additional testing should include privileged session monitoring, password rotation verification, account lifecycle validation, and periodic access recertification reviews. Security analysts should verify that authentication events are successfully forwarded to Splunk Enterprise Security SIEM and that anomalous authentication behavior generates appropriate alerts (Rose et al., 2020).

4.6 Splunk Enterprise Security SIEM Validation

Validation of Splunk Enterprise Security should confirm that security events are successfully collected from all enterprise log sources, including Active Directory, firewalls, servers, endpoints, cloud resources, and vulnerability management platforms. Correlation searches should be tested using simulated attack scenarios to verify accurate detection of suspicious authentication activity, malware execution, privilege escalation, and lateral movement (NIST, 2020a).

Risk-Based Alerting (RBA), dashboards, and automated notification workflows should also be validated to ensure that high-risk events generate timely alerts and provide sufficient context for effective incident investigation (NIST, 2022).

4.7 Endpoint Detection and Response Validation

Endpoint Detection and Response validation should include controlled simulations of malware execution, ransomware behavior, unauthorized PowerShell activity, credential dumping attempts, and suspicious administrative commands (NIST, 2022). Testing should verify that the

EDR platform detects malicious behavior, generates alerts, isolates compromised endpoints, preserves forensic evidence, and forwards telemetry to Splunk Enterprise Security SIEM.

Threat hunting exercises should also be performed using historical endpoint telemetry to evaluate the organization's ability to identify attacker techniques that may evade automated detection rules (CISA, 2023).

4.8 Vulnerability Management Validation

Validation of the vulnerability management program should begin with authenticated enterprise vulnerability scans to verify visibility across servers, workstations, network devices, cloud resources, and applications (NIST, 2022). Security assessors should confirm that newly identified vulnerabilities are accurately prioritized according to organizational risk criteria and that remediation activities follow established service-level objectives.

Following patch deployment, verification scans should confirm successful remediation while configuration assessments validate compliance with CIS Benchmarks, Security Technical Implementation Guides (STIGs), and organizational security baselines. Executive reporting should demonstrate reductions in outstanding vulnerabilities and measurable improvements in enterprise security posture (NIST, 2020a).

Table 4-3. Security Control Success Metrics

Performance Metric	Target
Multi-Factor Authentication Coverage	100% of privileged accounts
Credentialed Vulnerability Scan Coverage	≥95% of enterprise assets
Critical Vulnerability Remediation	Within 48 hours
High Severity Vulnerability Remediation	Within 7 days
Mean Time to Detect (MTTD)	Continuous improvement
Mean Time to Respond (MTTR)	Continuous improvement
SIEM Log Source Coverage	100% of critical systems
Endpoint Detection Coverage	100% of managed endpoints
Firewall Policy Compliance	100% approved rule validation
Successful Backup Recovery Testing	Quarterly

The performance metrics summarized in Table 4-3 provide measurable indicators for evaluating the ongoing effectiveness of controls after implementation and support continuous cybersecurity improvement (NIST, 2022).

4.9 Continuous Monitoring and Assessment

Security control validation should not be viewed as a one-time implementation activity. FICBANK should establish a continuous assessment program that includes periodic vulnerability scanning, firewall reviews, authentication testing, endpoint simulations, log correlation validation, and annual independent security assessments. Continuous monitoring enables the organization to identify emerging vulnerabilities, validate ongoing control effectiveness, and demonstrate continued compliance with organizational policies and regulatory requirements (NIST, 2022).

By integrating ongoing assessment activities with Splunk Enterprise Security, Endpoint Detection and Response, vulnerability management, and identity governance processes, FICBANK can maintain a continuously improving cybersecurity program capable of adapting to evolving threats while supporting secure banking operations (NIST, 2020a).

5. Conclusion

The cybersecurity assessments conducted throughout the Network and Vulnerability Assessment, Security Monitoring Assessment, and Incident and IOC Investigation phases established a comprehensive understanding of FICBANK's current security posture by identifying technical vulnerabilities, operational weaknesses, and emerging cyber threats affecting the organization's information systems. Collectively, these assessments demonstrated that although foundational security capabilities are in place, the existing security architecture requires modernization to effectively defend against increasingly sophisticated cyberattacks targeting financial institutions. The exposed administrative services, limited network

segmentation, identity management weaknesses, incomplete vulnerability visibility, and evidence of reconnaissance and exploitation activity observed during previous engagements emphasize the need for a coordinated, enterprise-wide cybersecurity strategy rather than isolated technology improvements (NIST, 2020a).

This Technical Controls Report presents a comprehensive defense-in-depth strategy designed to address those identified risks through the implementation of complementary preventive, detective, corrective, and governance controls. The proposed Zero Trust Architecture establishes continuous identity verification and least-privilege access as foundational security principles, while network segmentation and internal firewalls reduce opportunities for lateral movement across enterprise systems. Identity and Access Management strengthens authentication, authorization, and privileged account governance, whereas Splunk Enterprise Security SIEM and Endpoint Detection and Response provide continuous visibility into enterprise activity, enabling rapid detection and response to malicious behavior. Finally, the recommended vulnerability management and patch governance program establishes a structured process for continuously identifying, prioritizing, remediating, and validating security weaknesses before they can be exploited (Rose et al., 2020; CISA, 2023).

Equally important, this report emphasizes that implementing technical controls alone does not guarantee effective cybersecurity. The accompanying Test and Evaluation Plan establishes a structured methodology for validating each recommended control using assessment procedures aligned with NIST Special Publication 800-53A Revision 5. Continuous assessment, authenticated vulnerability scanning, security monitoring, periodic configuration reviews, and ongoing governance activities ensure that implemented controls continue to operate effectively as FICBANK's technology environment and the cyber threat landscape evolve. This commitment

to continuous improvement strengthens organizational resilience while providing executive leadership with measurable assurance that cybersecurity investments produce meaningful reductions in enterprise risk (NIST, 2022).

Implementation of the recommendations presented throughout this report will significantly enhance the confidentiality, integrity, and availability of FICBANK's information assets while supporting regulatory compliance, operational resilience, and long-term business objectives. The proposed architecture aligns with recognized industry frameworks, including NIST SP 800-53 Rev. 5, NIST SP 800-207, the CISA Zero Trust Maturity Model, PCI DSS v4.0, FFIEC Cybersecurity Assessment guidance, and the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule, positioning FICBANK to better protect customer information, strengthen stakeholder confidence, and support future digital transformation initiatives. By implementing the recommendations presented throughout this report, FICBANK will establish a mature, defense-in-depth cybersecurity architecture capable of proactively reducing enterprise risk, improving operational resilience, strengthening regulatory readiness, and supporting secure digital banking services well into the future. More importantly, the recommended architecture establishes a sustainable cybersecurity governance model that enables continuous assessment, ongoing improvement, and long-term alignment with evolving industry standards and organizational objectives (NIST, 2020a; NIST, 2022).

References

Amazon Web Services. (2023). *Patch Management in AWS*.

Cybersecurity and Infrastructure Security Agency. (2023). *Zero Trust Maturity Model Version 2.0*.

Department of Defense. (2022). *Zero Trust Reference Architecture*.

National Institute of Standards and Technology. (2022). *Assessing Security and Privacy Controls in Information Systems and Organizations (SP 800-53A Rev. 5)*. (NIST SP 800-53A Rev. 5)

National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5)*. (NIST SP 800-53 Rev. 5)

Rose, S., et al. (2020). *Zero Trust Architecture (NIST SP 800-207)*. (NIST SP 800-207)